Member services architecture design

The platform serves representatives of two health plans while keeping every conversation scoped to one tenant and member. The implemented slice uses a Python CLI, supplied HTTP APIs, validated plan evidence and SQLite. The target below replaces local hosting and state with managed services in one approved AWS region; it is a deployment design, not a provisioned environment.

Primary deployment

API Gateway verifies federated workforce JWTs through Cognito before a trusted session service checks tenant and member authorisation. Stateless Lambda handlers run the bounded agent and mandatory tool gateway. Credentials are selected by trusted scope; explicit claim ownership is checked after retrieval. Model requests contain fixed-vocabulary routing features only. An approved model endpoint remains replaceable through the existing adapter contract.

Tenant S3 document stores feed provenance-validated retrieval with product, year and effective-date filters. DynamoDB conditional transactions hold session leases, budget reservations, approval digests, canonical grievance bodies and operation results. Projected claim caches use conversation/member keys and application expiry. An audit outbox is checkpointed to tenant S3 Object Lock stores with six-year retention, KMS encryption and restricted readers. Secrets Manager, controlled egress and safe CloudWatch metrics support operation.

Requirements and constraints

Lambda's multi-AZ operation supports regional resilience, but 99.99 percent end-to-end availability is not established by one component. A 30-day error budget is about 4.32 minutes. Region loss and external vendor failures remain unmitigated by year-one multi-region spend. Use canaries, dependency SLOs, regional restore tests and measured capacity before claiming the target.

At 20,000 conversations daily, USD 0.03 permits USD 600 per day in combined model and infrastructure cost. Meter both; compare low idle-cost serverless hosting against provisioned readiness only after cold-start and burst tests. A 250-rep peak requires declared turn rates, quotas and tenant fairness. Fresh sequential claims pages take 1.5 seconds each, so universal sub-three-second complete pagination needs an upstream aggregate or an approved freshness contract.

Verification evidence

The local suite passes 86 tests. The unmodified external pack scores 37/40 with observed safety checks passing; three source/expectation conflicts keep the strict quality gate red. Pack p95 is 4.625 seconds in rules mode. Live-model evaluation, production cost, six-year archive operation and peak load remain unvalidated.

Threat model and write protocol

Assets are member facts, tenant credentials, representative authorisation, immutable approval evidence, write operations and audit records. Trust changes at the caller/session, source/agent, gateway/adapter, application/store and application/vendor boundaries. The local CLI trusts its operator; production identity and storage controls are additional deployment work.

Boundary	Threat	Enforcement
Representative to session	Forged tenant or member reference	Production JWT and member access checks; local CLI trusts its operator. Gateway rejects scope overrides.
Source to agent	KB, notes or manifest injection	Provenance quarantine, structured evidence and reviewed schemas. Model cannot approve writes.
Adapter to API	Wrong owner or hostile next link	Bound paths, ownership checks, same-scope pagination validation and disabled redirects.
State to backend	Replay, changed payload or lost ack	Approval digest and expiry, durable operation, identical key/body retries; uncertain operations retained.
Data to model or logs	Identity and clinical disclosure	Fixed-vocabulary model features, projected tool results, safe event schema and tenant-restricted audit readers.
Dependency to budget	429, outage, cost or latency exhaustion	Deadline and step checks, bounded retries with Retry-After, pre-call model reservation and no partial counts.

Approved operation protocol

DRAFT becomes APPROVED only after explicit representative confirmation of the displayed member-agreed summary. Approval binds scope and the canonical body hash and expires if unsent. Persist IN_FLIGHT before sending. On timeout or 503, preserve the operation and repeat the same key and bytes. Persist COMPLETED before returning success. Cancellation is permitted only for a draft; repeated confirmation returns the original result.

Exactly-once effect is conditional on durable local and upstream idempotency state. The supplied mock can commit before 503 and loses its state on restart. Production must specify upstream retention and reconciliation contracts. Pending operations, altered bodies, outbox lag and denied scope changes are monitored without raw clinical text.

Residual risks

A compromised trusted host, stale cache within its approved window, model misclassification, regional outage and downstream incident remain risks. Use access-controlled encrypted state, scoped IAM and tenant archives, independent safety tests, provider-specific evaluation and restore exercises. store=false is not a substitute for a provider retention agreement.

Azure deployment mapping

Year-two deployment into the second health plan's own Azure tenancy preserves application contracts while replacing hosting, identity, state and audit adapters. Keep all services in one approved region unless a separate availability and spending decision changes that constraint.

Responsibility	AWS	Azure
Workforce identity	Cognito federation and verified JWT	Microsoft Entra ID and verified application claims
API boundary	API Gateway HTTP API	API Management or Functions ingress with equivalent JWT checks
Application runtime	Lambda stateless handlers	Functions Flex Consumption with measured concurrency and readiness
Durable state	DynamoDB conditional transactions	Cosmos DB transactional batch within a session partition and ETag conditions
KB and cache	Tenant S3 document stores and state TTL	Tenant Blob containers and Cosmos TTL with application freshness checks
Immutable audit	S3 Object Lock with six-year retention	Blob immutable time-based locked policy with six-year retention
Secrets and keys	Secrets Manager and KMS	Key Vault and managed identities with equivalent access separation
Monitoring	CloudWatch metrics and alarms	Azure Monitor and Application Insights with the same event schema

Migration invariants

Preserve tenant identity, session and operation IDs, canonical request bytes and approval digests. DynamoDB conditions map to Cosmos ETag checks and transactional batches within a session partition. Revalidate lease fencing, budget reservations and retry races. TTL deletion is asynchronous on managed stores, so application expiry checks remain mandatory.

Re-issue scoped credentials and identity mappings; retest member access and all external egress allowlists. Transfer KB versions with provenance manifests. Retain old audit archives under their existing policies until the required retention and transfer controls are satisfied. Re-run quality, isolation, write recovery, latency, load and cost evidence before cutover.

Azure Functions Flex Consumption

Azure Blob immutable storage

Architecture decision records

ADR 1 Gateway as the policy boundary

A valid downstream token does not establish tenant authorisation. Bind every tool to a verified session and recheck member ownership. Alternatives were prompt-only controls and trusting backend routes. This adds checks and tests but keeps model or source behaviour from changing scope.

ADR 2 Structured and versioned evidence

The small KB contains mixed years and conflicting tenant provenance. Validate folder and metadata agreement and retrieve table evidence by tenant, product, year and effective date. A vector-only index or folder-only filter was rejected. Conflicts fail closed and citations remain reproducible; prose-only extensions need a reviewed parser.

ADR 3 Durable approved operation

A grievance may commit before a 503. Persist the canonical body, approval digest and operation key before sending. Retry the same bytes and key. A new key per attempt or model-managed confirmation was rejected. This requires durable state and downstream idempotency retention; it guarantees an effect only within that contract.

ADR 4 Bounded claim reuse

Sequential claims pages dominate latency. Use date-aware complete retrieval and a 30-second conversation/member cache of projected fields, display age, and permit TTL zero. Global raw-record caches and speculative page fan-out were rejected. Fresh complete counts remain slower; cache scope and expiration are explicitly tested.

ADR 5 Single region and replaceable services

Low approved spend and year-two portability favour a stateless serverless target with isolated tenant stores and provider adapters. Always-on Kubernetes and year-one multi-region replication were rejected for this workload. AWS to Azure migration needs semantic storage and identity adapters; multi-AZ hosting cannot remove regional or vendor failure risk.

Design references

AWS Lambda resilience

Amazon S3 Object Lock

Production architecture diagram

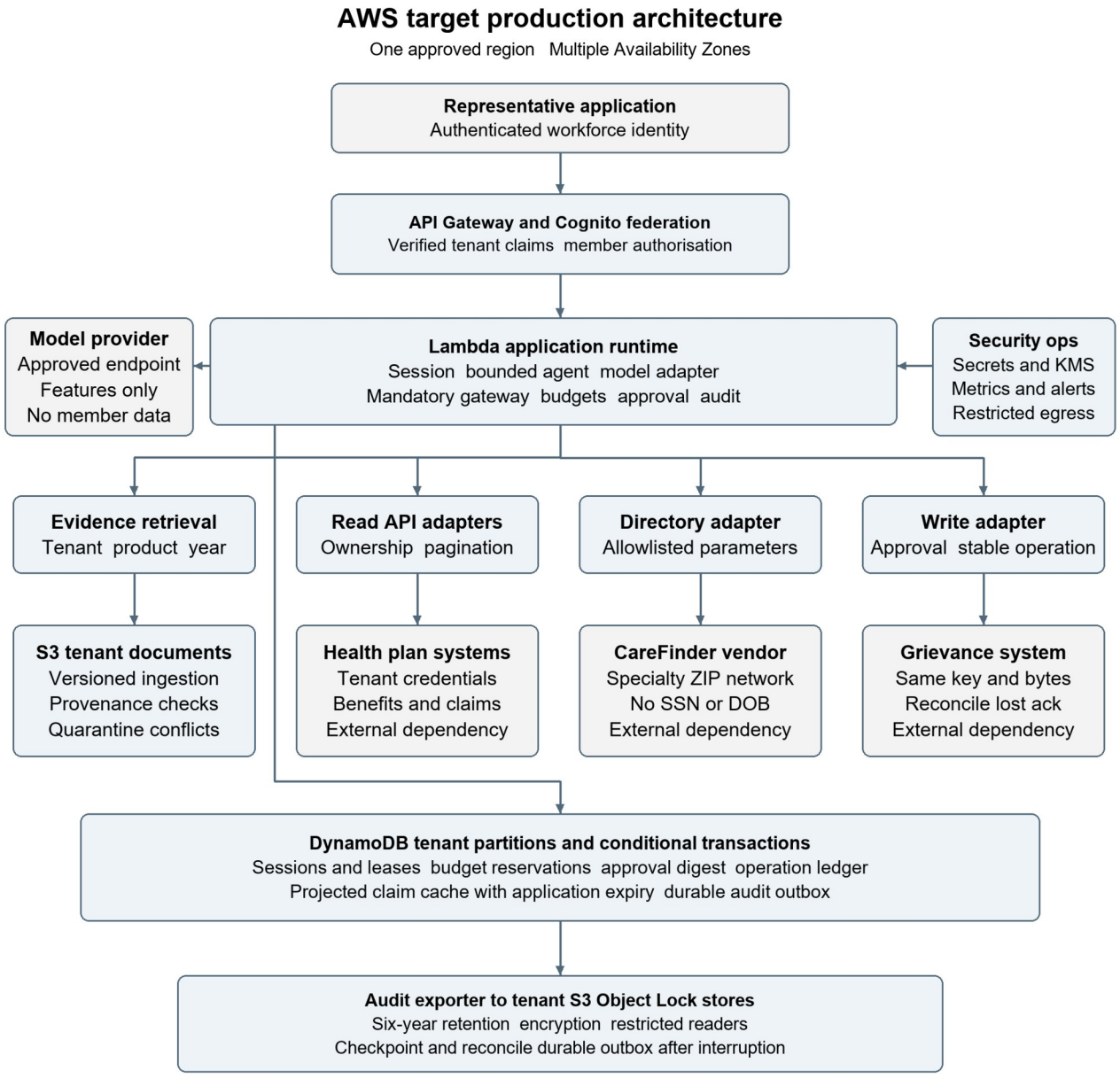


Figure 1 Proposed single-region hosting and application trust boundaries